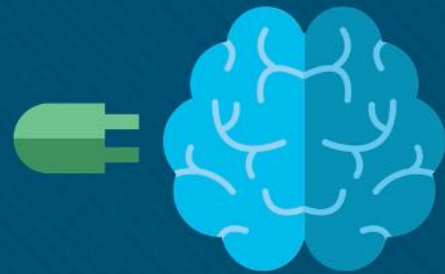




Module 14: Layer 2 Security Considerations

Networking Security v1.0
(NETSEC)



Module Objectives

Module Title: Layer 2 Security Considerations

Module Objective: Implement security measures to mitigate Layer 2 attacks.

Topic Title	Topic Objective
Layer 2 Security Threats	Describe Layer 2 vulnerabilities.
MAC Table Attacks	Describe MAC address spoofing attacks.
Mitigate MAC Table Attacks	Configure port security.
Mitigate VLAN Attacks	Explain how to mitigate VLAN attacks.
Mitigate DHCP Attacks	Use the correct commands to implement DHCP Snooping for attack mitigation.
Mitigate ARP Attacks	Use the correct commands to mitigate ARP attacks.
Mitigate Address Spoofing Attacks	Use the correct commands to mitigate address spoofing attacks.
Spanning Tree Protocol	Explain the operation of Spanning Tree Protocol.
Mitigate STP Attacks	Configure security measures to mitigate STP attacks.

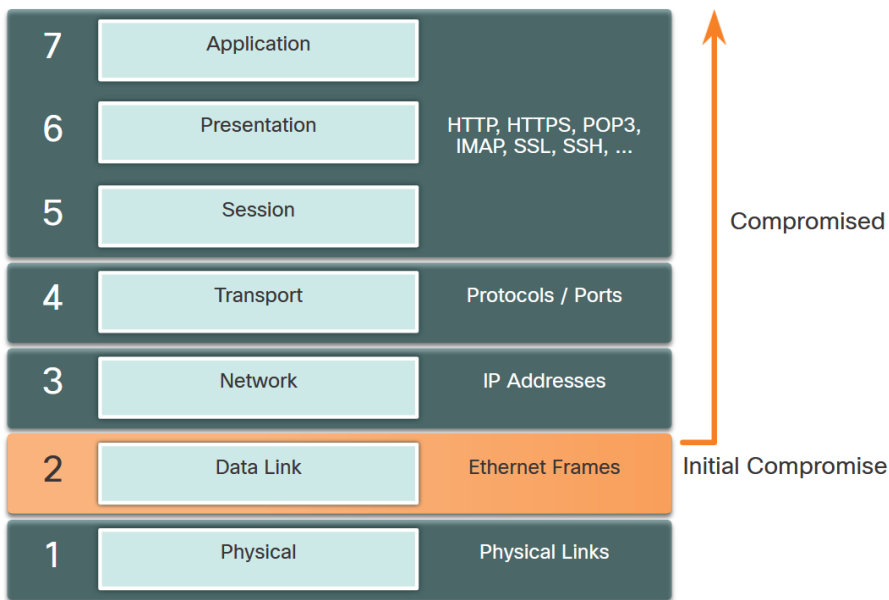
14.1 Layer 2 Security Threats

Layer 2 Security Threats

Describe Layer 2 Vulnerabilities

The OSI reference model is divided into seven layers which work independently of each other. Each layer performs a specific function and has core elements that can be exploited.

Network administrators routinely implement security solutions to protect the elements in Layer 3 up through Layer 7 using VPNs, firewalls, and IPS devices. However, as shown in the figure, if Layer 2 is compromised, then all layers above it are also affected.



Layer 2 Security Threats

Switch Attack Categories

Layer 2 is considered to be the weakest link in the network system. Attacks against the Layer 2 LAN infrastructure are highlighted in the table.

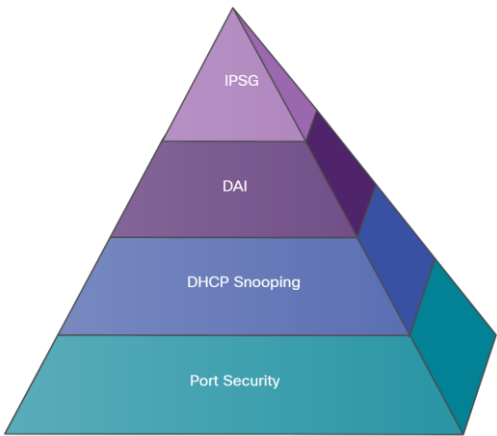
Type	Description
MAC Table Attacks	Includes MAC table overflow (also called MAC Address Flooding) Attacks.
VLAN Attacks	Includes VLAN hopping and VLAN double-tagging attacks. It also includes attacks between devices on a common VLAN.
DHCP Attacks	Includes DHCP starvation and DHCP spoofing attacks.
ARP Attacks	Includes ARP spoofing and ARP poisoning attacks.
Address Spoofing Attacks	Includes MAC Address and IP address spoofing attacks.
STP Attacks	Includes Spanning Tree Protocol manipulation attacks.

Switch Attack Categories (Cont.)

The figure provides an overview of Cisco solutions that help mitigate Layer 2 attacks.

The following strategies are recommended:

- Always use secure variants of these protocols such as SSH, SCP, and SSL.
- Consider using out-of-band (OOB) management.
- Use a dedicated management VLAN where nothing but management traffic resides.
- Use ACLs to filter unwanted access.



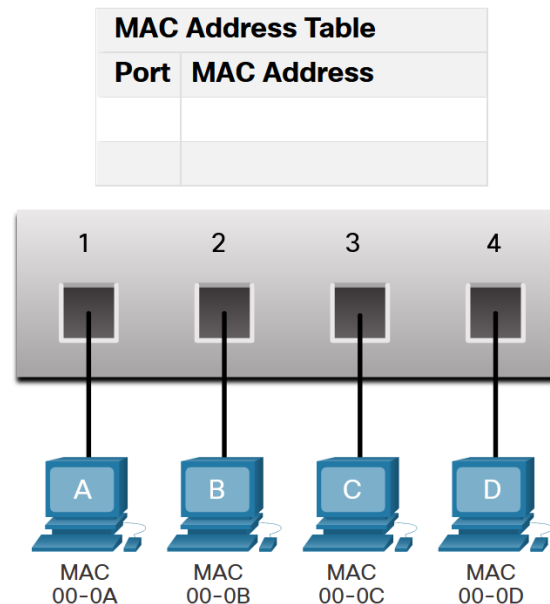
Topic Title	Topic Objective
Port Security	Port security prevents many types of attacks including MAC table overflow attacks and DHCP starvation attacks.
DHCP Snooping	DHCP Snooping prevents DHCP starvation and DHCP spoofing attacks by rogue DHCP servers.
Dynamic ARP Inspection (DAI)	DAI prevents ARP spoofing and ARP poisoning attacks.
IP Source Guard (IPSG)	IP Source Guard prevents MAC and IP address spoofing attacks.

14.2 MAC Table Attacks

Switch Fundamentals

A Layer 2 Ethernet switch uses Layer 2 MAC addresses to make forwarding decisions. It is completely unaware of the data (protocol) being carried in the data portion of the frame, such as an IPv4 packet, an ARP message, or an IPv6 ND packet. The switch makes its forwarding decisions based solely on the Layer 2 Ethernet MAC addresses.

The table shows the MAC Address Table which has not yet learned the MAC addresses for the four attached PCs.



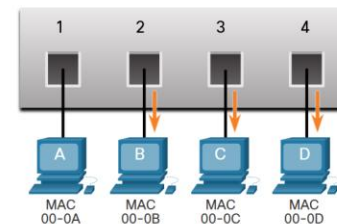
Switch Learning and Forwarding

The switch dynamically builds the MAC address table by examining the source MAC address of the frames that are received on a port. The switch forwards frames by searching for a match between the destination MAC address in the frame and an entry in the MAC address table.

Every frame that enters a switch is checked for new information to learn. The switch does this by examining the source MAC address of the frame and the port number where the frame entered the switch.

If the source MAC address does not exist, it is added to the table along with the incoming port number. If the source MAC address does exist, the switch updates the refresh timer for that entry in the table. By default, most Ethernet switches keep an entry in the table for 5 minutes.

MAC Address Table	
Port	MAC Address
1	00-0A



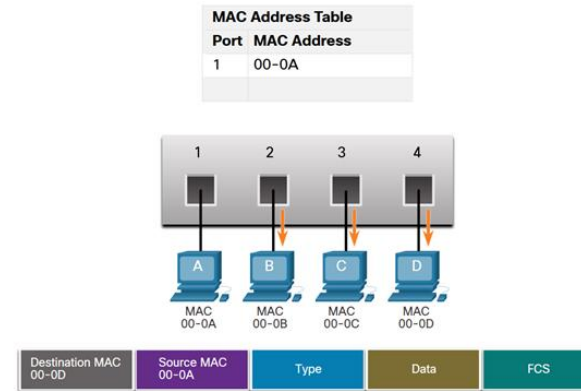
Destination MAC	Source MAC	Type	Data	FCS
00-0D	00-0A			

1. The destination MAC address is not in the table.
2. The switch forwards the frame out all other ports.

Switch Learning and Forwarding (Cont.)

If the destination MAC address is a unicast address, the switch will look for a match between the destination MAC address of the frame and an entry in its MAC address table. If the destination MAC address is in the table, it will forward the frame out the specified port. If the destination MAC address is not in the table, the switch will forward the frame out all ports except the incoming port. This is called an unknown unicast.

As shown in the figure, the switch does not have the destination MAC address in its table for PC-D, so it sends the frame out all ports except port 1.



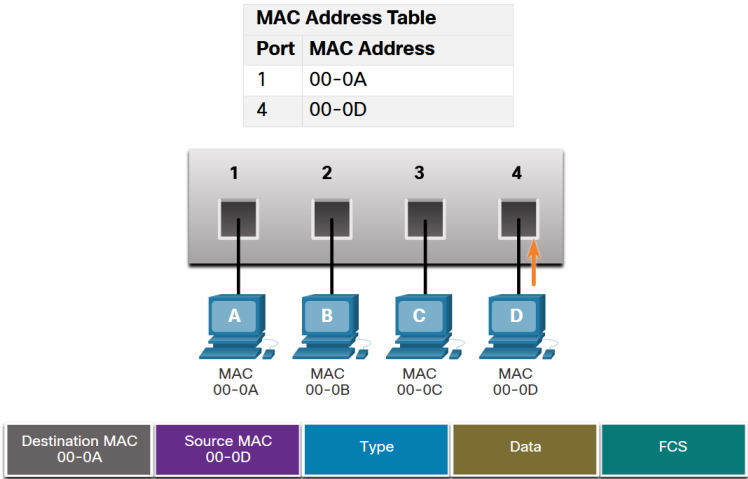
1. The destination MAC address is not in the table.
2. The switch forwards the frame out all other ports.

MAC Table Attacks

Filtering Frames

As a switch receives frames from different devices, it populates its MAC address table by examining the source MAC address of every frame. When the MAC address table of the switch contains the destination MAC address, it filters the frame and forwards out a single port.

In the figure, PC-D is replying back to PC-A. The switch sees the MAC address of PC-D in the incoming frame on port 4. The switch then puts the MAC address of PC-D into the MAC Address Table associated with port 4.

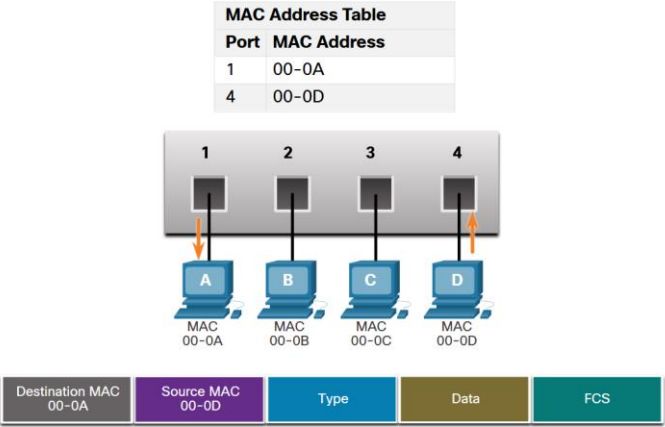


The switch adds the port number and MAC address for PC-D to its MAC address table.

MAC Table Attacks

Filtering Frames (Cont.)

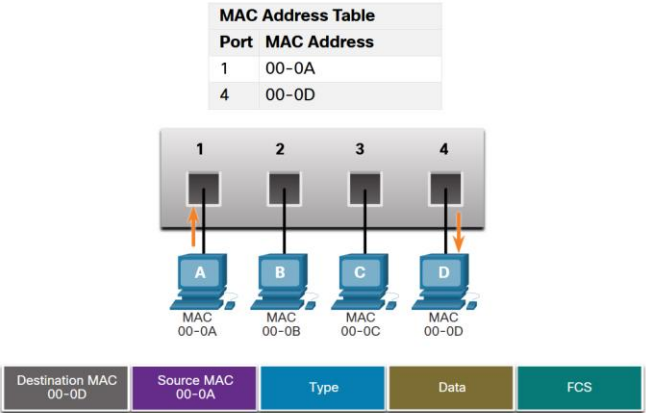
Next, because the switch has destination MAC address for PC-A in the MAC Address Table, it will send the frame only out port 1, as shown in the figure.



- 1. The switch has a MAC address entry for the destination.
- 2. The switch filters the frame, sending it only out port 1.



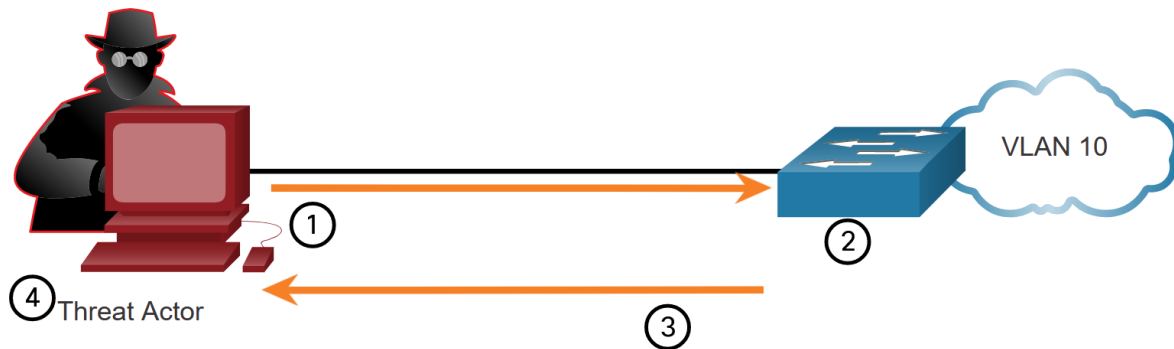
PC-A sends another frame to PC-D as shown in the figure. The MAC address table already contains the MAC address for PC-A; therefore, the five-minute refresh timer for that entry is reset. Next, because the switch table contains the destination MAC address for PC-D, it sends the frame only out port 4.



- 1. The switch receives another frame from PC-A and refreshes the timer for the MAC address entry for port 1.
- 2. The switch has a recent entry for the destination MAC address and filters the frame, forwarding it only out port 4.

MAC Address Table Flooding

All MAC tables have a fixed size and consequently, a switch can run out of resources in which to store MAC addresses. MAC address flooding attacks take advantage of this limitation by bombarding the switch with fake source MAC addresses until the switch MAC address table is full.



1. The threat actor is connected to VLAN 10 and uses **macof** to rapidly generate many random source and destination MAC and IP addresses.
2. Over a short period of time, the switch's MAC table fills up.
3. When the MAC table is full, the switch begins to flood all frames that it receives. As long as **macof** continues to run, the MAC table remains full and the switch continues to flood all incoming frames out every port associated with VLAN 10.
4. The threat actor then uses packet sniffing software to capture frames from any and all devices connected to VLAN 10.

MAC Address Table Attack Mitigation

What makes tools such as **macof** so dangerous is that an attacker can create a MAC table overflow attack very quickly. These attack tools are dangerous because they not only affect the local switch, but because they can also affect other connected Layer 2 switches.

To mitigate MAC address table overflow attacks, network administrators must implement port security. Port security will only allow a specified number of source MAC addresses to be learned on the port.

14.3 Mitigate MAC Table Attacks

Secure Unused Ports

All switch ports (interfaces) should be secured before the switch is deployed for production use. How a port is secured depends on its function.

A simple method that many administrators use to help secure the network from unauthorized access is to disable all unused ports on a switch.

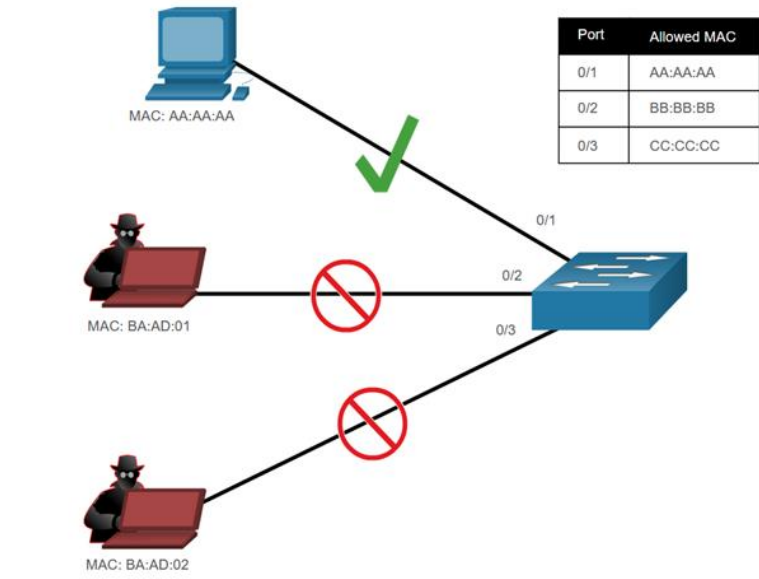
```
S1(config)# interface range fa0/8 - 24
S1(config-if-range)# shutdown
%LINK-5-CHANGED: Interface FastEthernet0/8, changed state to administratively down
(output omitted)
%LINK-5-CHANGED: Interface FastEthernet0/24, changed state to administratively down
S1(config-if-range)#
```


Mitigate MAC Table Attacks

Mitigate MAC Address Table Attacks

Port security limits the number of valid MAC addresses allowed on a port. It allows an administrator to manually configure MAC addresses for a port or to permit the switch to dynamically learn a limited number of MAC addresses. When a port that is configured with port security receives a frame, the source MAC address of the frame is compared to the list of secure source MAC addresses that were manually configured or dynamically learned on the port.

By limiting the number of permitted MAC addresses on a port to one, port security can be used to control unauthorized access to the network, as shown in the figure.



Note: MAC addresses are shown as 24 bits for simplicity.

Mitigate MAC Table Attacks

Enable Port Security

The **switchport port-security** interface configuration command for port security can only be configured on manually configured access ports or manually configured trunk ports. By default, Layer 2 switch ports are set to dynamic auto (trunking on).

Use the **show port-security interface** command to display the current port security settings for FastEthernet 0/1, as shown in the example. Notice that port security is enabled, and the port status is Secure-down, which means there are no devices attached and no violation has occurred. Also, the violation mode is Shutdown, and the maximum number of MAC addresses allowed is 1.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security
Command rejected: FastEthernet0/1 is a dynamic port.
S1(config-if)# switchport mode access
S1(config-if)# switchport port-security
S1(config-if)# end
S1#
```

```
S1# show port-security interface f0/1
Port Security                : Enabled
Port Status                  : Secure-down
Violation Mode                : Shutdown
Aging Time                   : 0 mins
Aging Type                    : Absolute
SecureStatic Address Aging   : Disabled
Maximum MAC Addresses        : 1
Total MAC Addresses          : 0
Configured MAC Addresses     : 0
Sticky MAC Addresses         : 0
Last Source Address:Vlan     : 0000.0000.0000:0
Security Violation Count     : 0
S1#
```

Limit and Learn MAC Addresses

To set the maximum number of MAC addresses allowed on a port, use the **switchport port-security maximum** *value* command.

The switch can be configured to learn about MAC addresses on a secure port in one of three ways:

1. **Manually Configured** - The administrator manually configures a static MAC address(es) by using the **switchport port-security mac-address** *mac-address* command for each secure MAC address on the port.
2. **Dynamically Learned** - When the **switchport port-security** command is entered, the current source MAC for the device connected to the port is automatically secured but is not added to the startup configuration. If the switch is rebooted, the port will have to re-learn the device's MAC address.
3. **Dynamically Learned – Sticky** - The administrator can enable the switch to dynamically learn the MAC address and “stick” them to the running configuration by using the **switchport port-security mac-address sticky** command.

Port Security Aging

Port security aging can be used to set the aging time for static and dynamic secure addresses on a port. Two types of aging are supported per port:

- **Absolute** - The secure addresses on the port are deleted after the specified aging time.
- **Inactivity** - The secure addresses on the port are deleted only if they are inactive for the specified aging time.

Use aging to remove secure MAC addresses on a secure port without manually deleting the existing secure MAC addresses.

Parameter	Description
<code>static</code>	Enable aging for statically configured secure addresses on this port.
<code>time time</code>	Specify the aging time for this port. The range is 0 to 1440 minutes. If the time is 0, aging is disabled for this port.
<code>type absolute</code>	Set the absolute aging time. All the secure addresses on this port age out exactly after the time (in minutes) specified and are removed from the secure address list.
<code>type inactivity</code>	Set the inactivity aging type. The secure addresses on this port age out only if there is no data traffic from the secure source address for the specified time period.

Port Security Violation Modes

If the MAC address of a device that is attached to the port differs from the list of secure addresses, then a port violation occurs. By default, the port enters the error-disabled state. To set the port security violation mode, use the **switchport port-security violation { protect | restrict | shutdown }** command.

The following table shows security violation mode descriptions.

Mode	Description
shutdown (default)	The port transitions to the error-disabled state immediately, turns off the port LED, and sends a syslog message. It increments the violation counter. When a secure port is in the error-disabled state, an administrator must re-enable it by entering the shutdown and no shutdown commands.
restrict	The port drops packets with unknown source addresses until you remove a sufficient number of secure MAC addresses to drop below the maximum value or increase the maximum value. This mode causes the Security Violation counter to increment and generates a syslog message.
protect	This is the least secure of the security violation modes. The port drops packets with unknown MAC source addresses until you remove a sufficient number of secure MAC addresses to drop below the maximum value or increase the maximum value. No syslog message is sent.

Port Security Violation Modes (Cont.)

The following table shows a security violation mode comparison.

Violation Mode	Discards Offending Traffic	Sends Syslog Message	Increase Violation Counter	Shuts Down Port
Protect	Yes	No	No	No
Restrict	Yes	Yes	Yes	No
Shutdown	Yes	Yes	Yes	Yes

The figure on the right, shows an administrator changing the security violation to “restrict”. The output of the **show port-security interface** command confirms that the change has been made.

```
S1(config)# interface f0/1
S1(config-if)# switchport port-security violation restrict
S1(config-if)# end
S1#
S1# show port-security interface f0/1
Port Security           : Enabled
Port Status             : Secure-up
Violation Mode          : Restrict
Aging Time              : 10 mins
Aging Type              : Inactivity
SecureStatic Address Aging : Disabled
Maximum MAC Addresses   : 2
Total MAC Addresses     : 2
Configured MAC Addresses : 1
Sticky MAC Addresses    : 1
Last Source Address:Vlan : a41f.7272.676a:1
Security Violation Count : 0
S1#
```

Ports in error-disabled State

What happens when the port security violation is shutdown and a port violation occurs? The port is physically shut down and placed in the error-disabled state, and no traffic is sent or received on that port.

In the example, the port security violation is changed back to the default shutdown setting. Then the host with MAC address a41f.7272.676a is disconnected and a new host is plugged into Fa0/1. Notice that a series of port security-related messages are generated on the console.

```
S1(config)# int fa0/1
S1(config-if)# switchport port-security violation shutdown
S1(config-if)# end
S1#
*Mar 1 00:24:15.599: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to down
*Mar 1 00:24:16.606: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
*Mar 1 00:24:19.114: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to up
*Mar 1 00:24:20.121: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to up
S1#
*Mar 1 00:24:32.829: %PM-4-ERR_DISABLE: psecure-violation error detected on Fa0/1, putting
Fa0/1 in err-disable state
*Mar 1 00:24:32.838: %PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused
by MAC address a41f.7273.018c on port FastEthernet0/1.
*Mar 1 00:24:33.836: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed
state to down
*Mar 1 00:24:34.843: %LINK-3-UPDOWN: Interface FastEthernet0/1, changed state to down
S1#
```

Verify Port Security

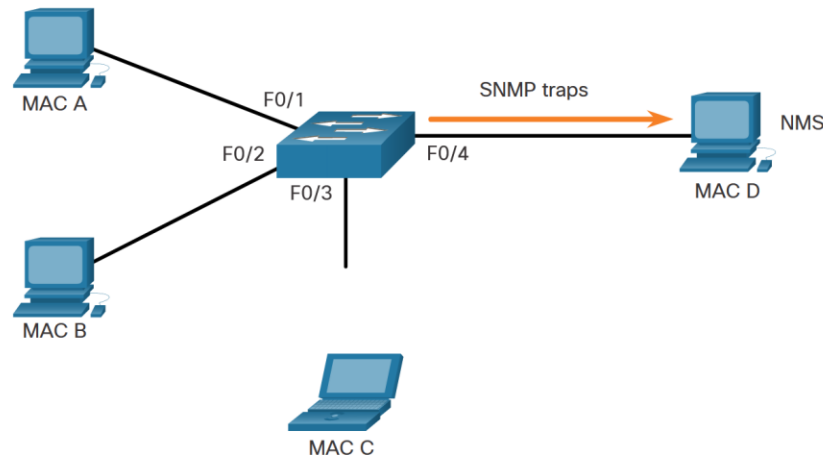
After configuring port security on a switch, check each interface to verify that the port security is set correctly, and check to ensure that the static MAC addresses have been configured correctly.

- To display port security settings for the switch, use the **show port-security** command.
- Use the **show port-security interface** command to view details for a specific interface.
- To verify that MAC addresses are “sticking” to the configuration, use the **show run** command.
- To display all secure MAC addresses that are manually configured or dynamically learned on all switch interfaces, use the **show port-security address** command.

SNMP MAC Address Notification

The MAC address notification feature sends SNMP traps to the network management station (NMS) whenever a new MAC address is added to, or an old address is deleted from, the forwarding tables. MAC address notifications are generated only for dynamic and secure MAC addresses.

Use the **mac address-table notification** global configuration command to enable the MAC address notification feature on a switch.



Packet Tracer - Implement Port Security

In this Packet Tracer activity, you will configure and verify port security on a switch. Port security allows you to restrict a port's ingress traffic by limiting the MAC addresses that are allowed to send traffic into the port.

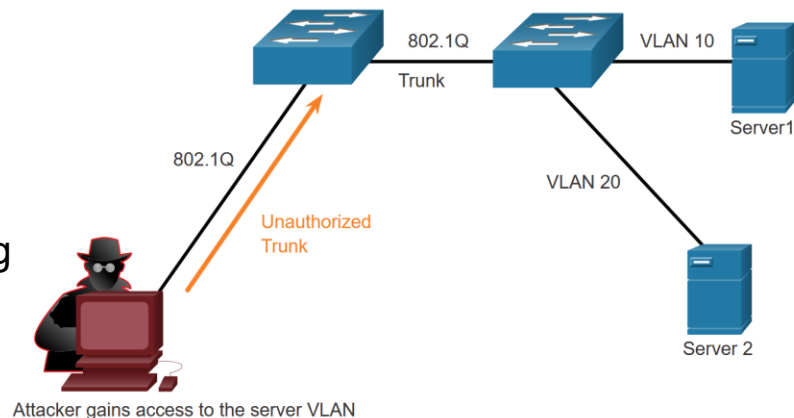
14.4 Mitigate VLAN Attacks

VLAN Hopping Attacks

Two types of VLAN attacks are VLAN hopping attacks and VLAN double-tagging attacks.

In a basic VLAN hopping attack, the threat actor configures a host to act like a switch to take advantage of the automatic trunking port feature enabled by default on most switch ports.

The threat actor configures the host to spoof 802.1Q signaling and Cisco-proprietary Dynamic Trunking Protocol (DTP) signaling to trunk with the connecting switch. If successful, the switch establishes a trunk link with the host, as shown in the figure. Now the threat actor can access all the VLANs on the switch. The threat actor can send and receive traffic on any VLAN, effectively hopping between VLANs.



VLAN Double-Tagging Attack

A threat actor in specific situations could embed a hidden 802.1Q tag inside the frame that already has an 802.1Q tag. This tag allows the frame to go to a VLAN that the original 802.1Q tag did not specify. The following explains the steps taken by the threat actor.

1. The threat actor sends a double-tagged 802.1Q frame to the switch. The outer header has the VLAN tag of the threat actor, which is the same as the native VLAN of the trunk port. For the purposes of this example, assume that this is VLAN 10. The inner tag is the victim VLAN.
2. The frame arrives on the first switch, which looks at the first 4-byte 802.1Q tag. The switch sees that the frame is destined for VLAN 10, which is the native VLAN. The switch forwards the packet out all VLAN 10 ports after stripping the VLAN 10 tag. The frame is not retagged because it is part of the native VLAN. At this point, the VLAN 20 tag is still intact and has not been inspected by the first switch.
3. The frame arrives at the second switch which has no knowledge that it was supposed to be for VLAN 10. Native VLAN traffic is not tagged by the sending switch as specified in the 802.1Q specification. The second switch looks only at the inner 802.1Q tag that the threat actor inserted and sees that the frame is destined for VLAN 20, the target VLAN. The second switch sends the frame on to the target or floods it, depending on whether there is an existing MAC address table entry for the target.

Mitigating VLAN Hopping Attacks

Use the following steps to mitigate VLAN hopping attacks:

Step 1: Disable DTP (auto trunking) negotiations on non-trunking ports by using the **switchport mode access** interface configuration command.

Step 2: Disable unused ports and put them in an unused VLAN. In the example it is VLAN 1000.

Step 3: Manually enable the trunk link on a trunking port by using the **switchport mode trunk** command.

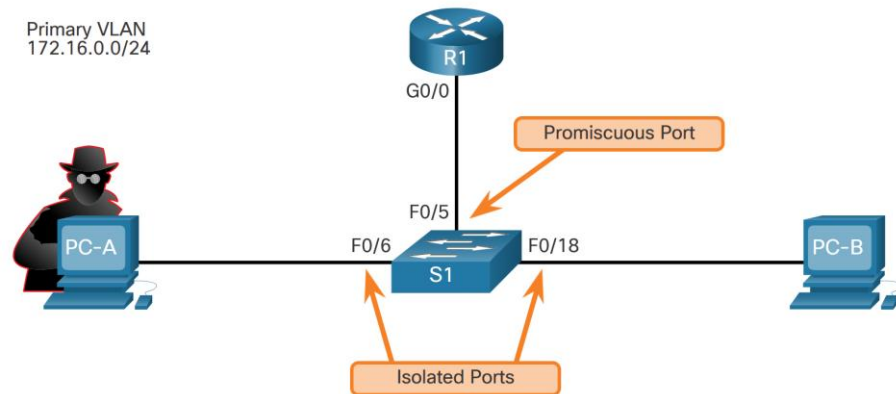
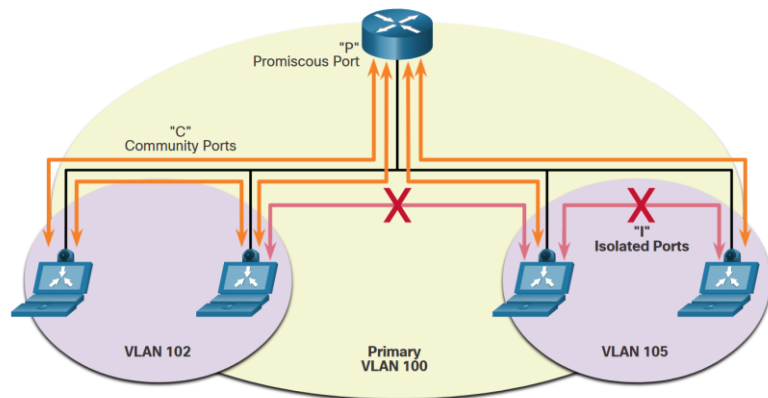
Step 4: Disable DTP (auto trunking) negotiations on trunking ports by using the **switchport nonegotiate** command.

Step 5: Set the native VLAN to a VLAN other than VLAN 1 by using the **switchport trunk native vlan *vlan_number*** command.

Private VLANs

Private VLANs (PVLAN) provide Layer 2 isolation between ports within the same broadcast domain. There are three types of PVLAN ports: promiscuous, isolated, and community.

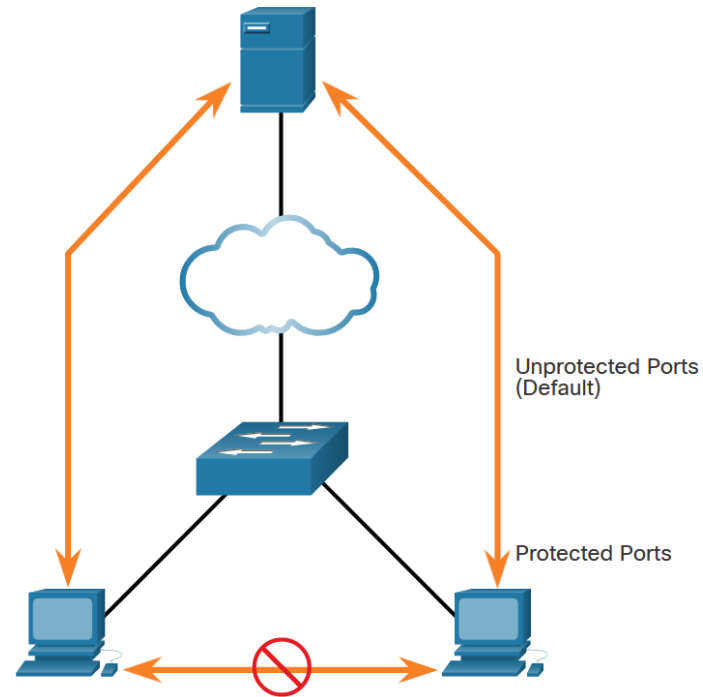
The example in the first figure illustrates which ports can interconnect. The security provided by a PVLAN can be bypassed by using the router as a proxy. The second figure is an example of an attack. To mitigate this type of attack, configure an ACL that will deny traffic with a source and destination IP address that belongs to the same subnet.



PVLAN Edge Feature

Some applications require that no traffic be forwarded at Layer 2 between ports on the same switch so that one neighbor does not see the traffic generated by another neighbor.

In such an environment, the use of the PVLAN Edge feature ensures that there is no exchange of unicast, broadcast, or multicast traffic between PVLAN edge ports on the switch, as shown in the figure. The PLVAN Edge feature is also called Protected Port.



Configure PVLAN Edge

- To configure the PVLAN Edge feature, enter the **switchport protected** interface configuration mode command.
- The PVLAN Edge feature can be configured on a physical interface or an EtherChannel group. When the PVLAN Edge feature is enabled for a port channel, it is enabled for all ports in the port-channel group. To disable protected port, use the **no switchport protected** interface configuration mode command.
- To verify the configuration of the PVLAN Edge feature, use the **show interfaces *interface-id* switchport** global configuration mode command.
- The PVLAN edge is a feature that has only local significance to the switch, and there is no isolation provided between two protected ports located on different switches.

Video - Private VLAN Tutorial and Demonstration

This video and tutorial demonstrates Private VLAN configuration and includes the following:

- Advantages of Private VLANs
- Examples of Private VLAN implementation
- Types of Private VLAN ports
- Configuration of Private VLANs on a 3560 Multilayer switch
- Use of the switchport protected command on a 2960 switch

14.5 Mitigate DHCP Attacks

DHCP Attacks

Two types of DHCP attacks are DHCP starvation and DHCP spoofing. Both attacks are mitigated by implementing DHCP snooping.

- **DHCP Starvation Attack** - The goal of the DHCP starvation attack is DoS for connecting clients. DHCP starvation attacks require an attack tool such as Gobblers.
- **DHCP Spoofing Attack** - A DHCP spoofing attack occurs when a rogue DHCP server is connected to the network and provides false IP configuration parameters to legitimate clients. A rogue server can provide a variety of misleading information including wrong default gateway, wrong DNS server, and wrong IP address.

DHCP Attacks Mitigation

It is easy to mitigate DHCP starvation attacks by using port security. However, mitigating DHCP spoofing attacks requires more protection.

DHCP spoofing attacks can be mitigated using DHCP snooping on trusted ports. DHCP snooping also helps mitigate against DHCP starvation attacks by rate limiting the number of DHCP discovery messages that an untrusted port can receive. DHCP snooping builds and maintains a DHCP snooping binding database that the switch can use to filter DHCP messages from untrusted sources.

When DHCP snooping is enabled on an interface or VLAN, and a switch receives a packet on an untrusted port, the switch compares the source packet information with the information held in the DHCP snooping binding table. The switch will deny packets containing specific information.

Steps to Implement DHCP Snooping

Use the following steps to enable DHCP snooping:

Step 1. Enable DHCP snooping by using the **ip dhcp snooping** global configuration command.

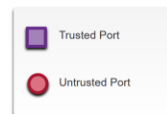
Step 2. On trusted ports, use the **ip dhcp snooping trust** interface configuration command.

Step 3. Limit the number of DHCP discovery messages that can be received per second on untrusted ports by using the **ip dhcp snooping limit rate** interface configuration command.

Step 4. Enable DHCP snooping by VLAN, or by a range of VLANs, by using the **ip dhcp snooping vlan** global configuration command.

DHCP Snooping Configuration Example

The reference topology for this DHCP snooping example is shown in the figure. Notice that F0/5 is an untrusted port because it connects to a PC. F0/1 is a trusted port because it connects to the DHCP server.



The following is an example of how to configure DHCP snooping on S1. Notice how DHCP snooping is first enabled.

```
S1(config)# ip dhcp snooping
S1(config)# interface f0/1
S1(config-if)# ip dhcp snooping trust
S1(config-if)# exit
S1(config)# interface range f0/5 - 24
S1(config-if-range)# ip dhcp snooping limit rate 6
S1(config-if-range)# exit
S1(config)# ip dhcp snooping vlan 5,10,50-52
S1(config)# end
S1#
```

Use the **show ip dhcp snooping** privileged EXEC command to verify DHCP snooping and **show ip dhcp snooping binding** to view the clients that have received DHCP information.

14.6 Mitigate ARP Attacks

ARP Attacks

In a typical attack, a threat actor can send unsolicited ARP Replies to other hosts on the subnet with the MAC Address of the threat actor and the IPv4 address of the default gateway.

There are many tools available on the internet to create ARP man-in-the-middle attacks including dsniff, Cain & Abel, ettercap, Yersinia, and others. IPv6 uses ICMPv6 Neighbor Discovery Protocol for Layer 2 address resolution. IPv6 includes strategies to mitigate Neighbor Advertisement spoofing, similar to the way IPv6 prevents a spoofed ARP Reply.

ARP spoofing and ARP poisoning are mitigated by implementing Dynamic ARP Inspection (DAI).

Video - ARP Spoofing

This video will explain ARP spoofing attacks.

Dynamic ARP Inspection

In a typical ARP attack, a threat actor can send unsolicited ARP requests to other hosts on the subnet with the MAC Address of the threat actor and the IP address of the default gateway.

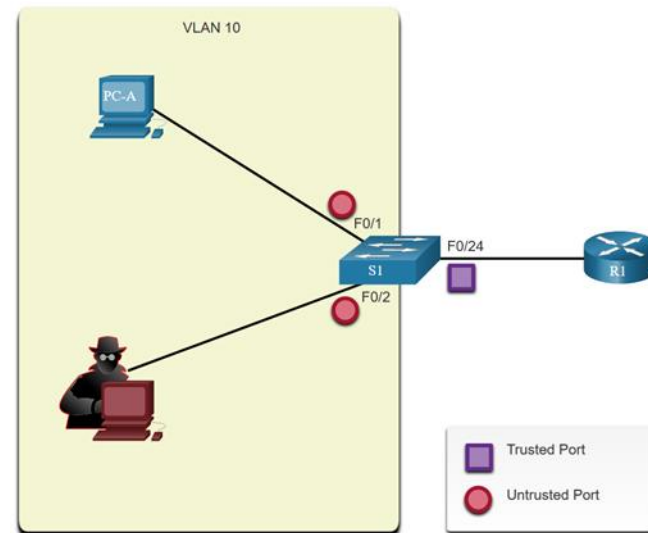
Dynamic ARP inspection (DAI) requires DHCP snooping and helps prevent ARP attacks by:

- Not relaying invalid or gratuitous ARP Requests out to other ports in the same VLAN.
- Intercepting all ARP Requests and Replies on untrusted ports.
- Verifying each intercepted packet for a valid IP-to-MAC binding.
- Dropping and logging ARP Requests coming from invalid sources to prevent ARP poisoning.
- Error-disabling the interface if the configured DAI number of ARP packets is exceeded.

DAI Implementation Guidelines

To mitigate the chances of ARP spoofing and ARP poisoning, follow these DAI implementation guidelines:

- Enable DHCP snooping globally.
- Enable DHCP snooping on selected VLANs.
- Enable DAI on selected VLANs.
- Configure trusted interfaces for DHCP snooping and ARP inspection.



DAI Configuration Example

In the previous topology, S1 is connecting two users on VLAN 10. DAI will be configured to mitigate against ARP spoofing and ARP poisoning attacks.

As shown in the example, DHCP snooping is enabled because DAI requires the DHCP snooping binding table to operate. Next, DHCP snooping and ARP inspection are enabled for the PCs on VLAN10. The uplink port to the router is trusted, and therefore, is configured as trusted for DHCP snooping and ARP inspection.

```
S1(config)# ip dhcp snooping
S1(config)# ip dhcp snooping vlan 10
S1(config)# ip arp inspection vlan 10
S1(config)# interface fa0/24
S1(config-if)# ip dhcp snooping trust
S1(config-if)# ip arp inspection trust
```

DAI Configuration Example (Cont.)

DAI can also be configured to check for both destination or source MAC and IP addresses:

- **Destination MAC** - Checks the destination MAC address in the Ethernet header against the target MAC address in the ARP packet body.
- **Source MAC** - Checks the source MAC address in the Ethernet header against the sender MAC address in the ARP packet body.
- **IP address** - Checks the ARP packet body for invalid and unexpected IP addresses including addresses 0.0.0.0, 255.255.255.255, and all IP multicast addresses.

DAI Configuration Example (Cont.)

The **ip arp inspection validate {src-mac [dst-mac] [ip]}** global configuration command is used to configure DAI to drop ARP packets when the IP addresses are invalid.

```
S1(config)# ip arp inspection validate ?
dst-mac  Validate destination MAC address
ip       Validate IP addresses
src-mac  Validate source MAC address
S1(config)# ip arp inspection validate src-mac
S1(config)# ip arp inspection validate dst-mac
S1(config)# ip arp inspection validate ip
S1(config)# do show run | include validate
ip arp inspection validate ip
S1(config)# ip arp inspection validate src-mac dst-mac ip
S1(config)# do show run | include validate
ip arp inspection validate src-mac dst-mac ip
S1(config)#
```

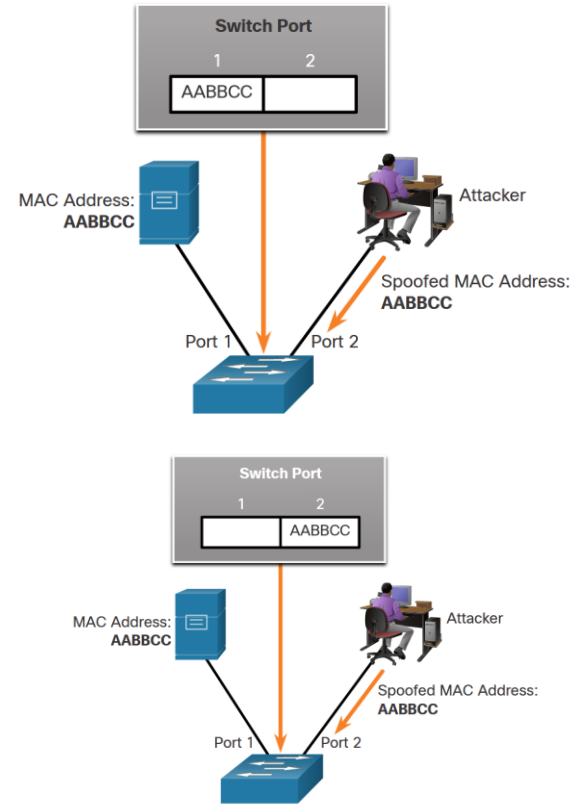
14.7 Mitigate Address Spoofing Attacks

Mitigate Address Spoofing Attacks

Address Spoofing Attacks

MAC address spoofing attacks occur when attackers alter the MAC address of their host to match another known MAC address of a target host, as shown in the first figure.

When the switch receives the frame, it examines the source MAC address. The switch overwrites the current MAC table entry and assigns the MAC address to the new port, as shown in the second figure. It then inadvertently forwards frames destined for the target host to the attacking host.



Address Spoofing Attack Mitigation

To protect against MAC and IP address spoofing, configure the IP Source Guard (IPSG) security feature. IPSG operates just like DAI, but it looks at every packet, not just the ARP packets. Like DAI, IPSG also requires that DHCP snooping be enabled.

For each untrusted port, there are two possible levels of IP traffic security filtering:

- **Source IP address filter** - IP traffic is filtered based on its source IP address and only IP traffic with a source IP address that matches the IP source binding entry is permitted. When a new IP source entry binding is created or deleted on the port, the per-port VLAN ACL (PVACL) automatically adjusts itself to reflect the IP source binding change.
- **Source IP and MAC address filter** - IP traffic is filtered based on its source IP address in addition to its MAC address. Only IP traffic with source IP and MAC addresses that match the IP source binding entry are permitted.

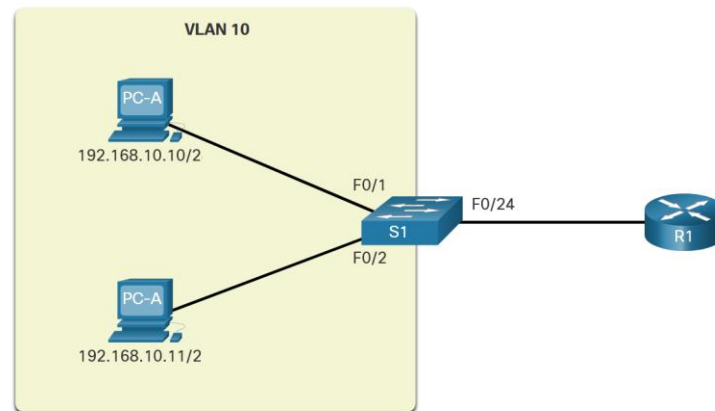
Mitigate Address Spoofing Attacks

Configure IP Source Guard

The IP Source Guard reference topology is shown in the figure on the right.

IP Source Guard is enabled on untrusted ports using the **ip verify source** command as shown in the configuration below.

Use the **show ip verify source** command to verify the IP Source Guard configuration.



```
S1(config)# interface range fastethernet 0/1 - 2
S1(config-if-range)# ip verify source
S1(config-if-range)# end
S1#
```

```
S1# show ip verify source
```

Interface	Filter-type	Filter-mode	IP-address	Mac-address	Vlan
F0/1	ip	active	192.168.10.10		10
F0/2	ip	active	192.168.10.11		10

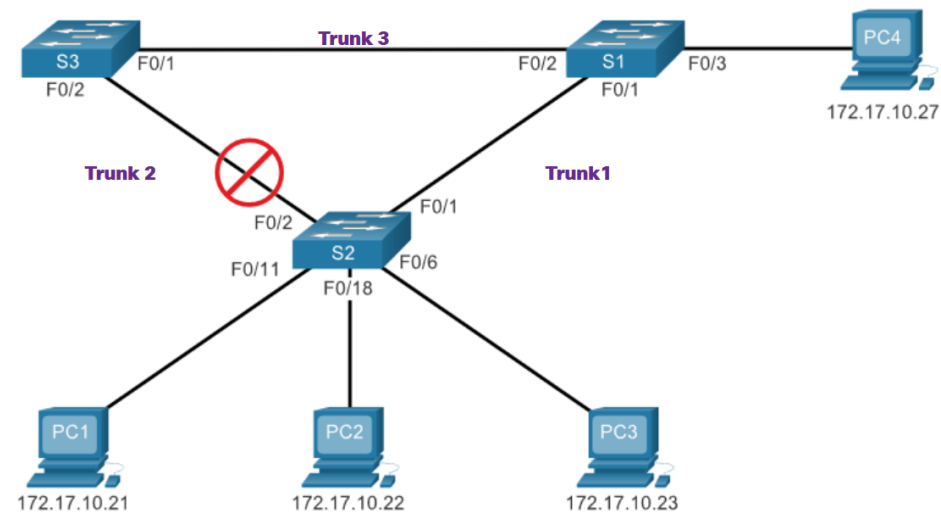
S1#

14.8 Spanning Tree Protocol

Spanning Tree Protocol

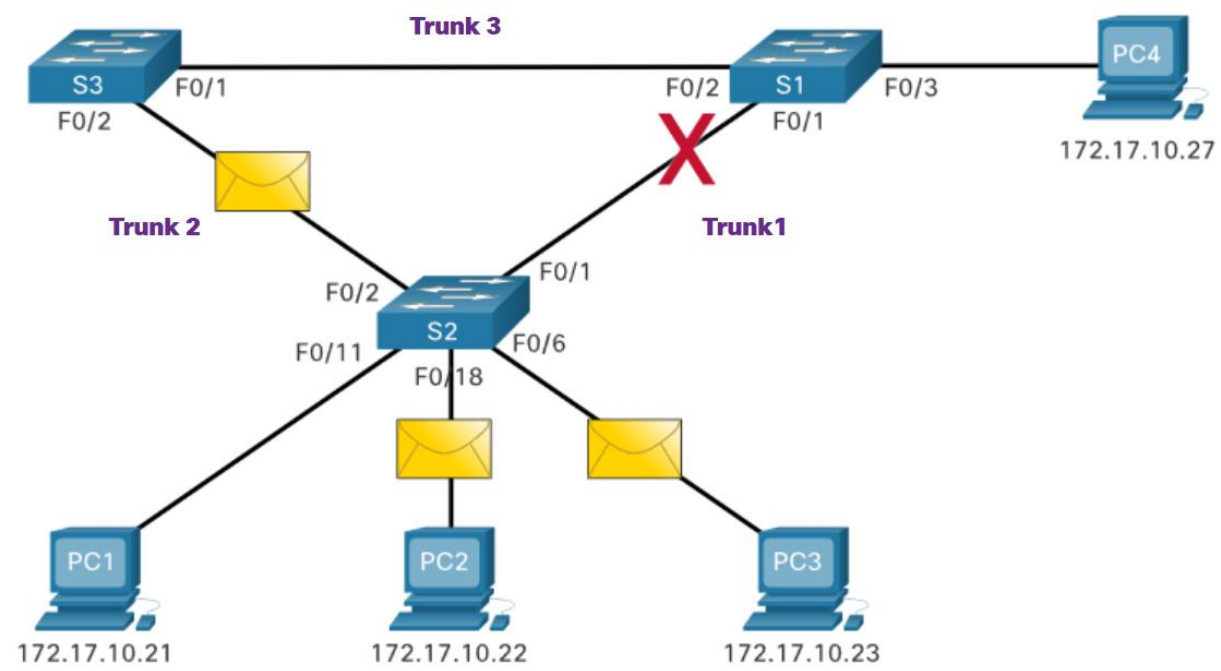
Spanning Tree Protocol

Spanning Tree Protocol (STP) is a loop-prevention network protocol that allows for redundancy while creating a loop-free Layer 2 topology. IEEE 802.1D is the original IEEE MAC Bridging standard for STP.



Spanning Tree Protocol

STP Recalculation



S2 forwards the broadcast out all switch ports, except the originating port and the failed link for Trunk1.

Layer 2 Loops

Without STP enabled, Layer 2 loops can form, causing broadcast, multicast and unknown unicast frames to loop endlessly. This can bring down a network within a very short amount of time.

When a loop occurs, the MAC address table on a switch will constantly change with the updates from the broadcast frames, which results in MAC database instability. This can cause high CPU utilization, which makes the switch unable to forward frames.

Broadcast frames are not the only type of frames that are affected by loops. Unknown unicast frames sent onto a looped network can result in duplicate frames arriving at the destination device.

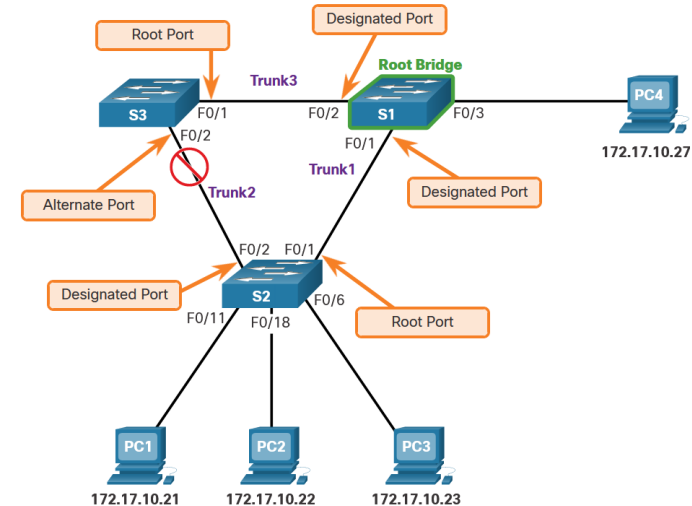
Spanning Tree Protocol

STP Port Roles

The spanning tree algorithm designates a single switch as the root bridge and uses it as the reference point for all path calculations.

In the figure, the root bridge (switch S1) is chosen through an election process. All switches that participate in STP exchange BPDUs to determine which switch has the lowest bridge ID (BID) on the network. The switch with the lowest BID automatically becomes the root bridge for the spanning tree algorithm calculations.

When the spanning tree algorithm has determined which paths are most desirable relative to each switch, it assigns port roles to the participating switch ports. The STP port roles are alternate, root, and designated.



STP Port Roles (Cont.)

The STP port roles are:

- **Alternate** - Alternate or backup ports are configured to be in a blocking state to prevent loops. Alternate ports are selected only on trunk links where neither end is a root port.
- **Root** - Root ports are switch ports that are closest to the root bridge.
- **Designated** - If one end of a trunk is a root port, then the other end is a designated port. All ports on the root bridge are designated ports.

Spanning Tree Protocol

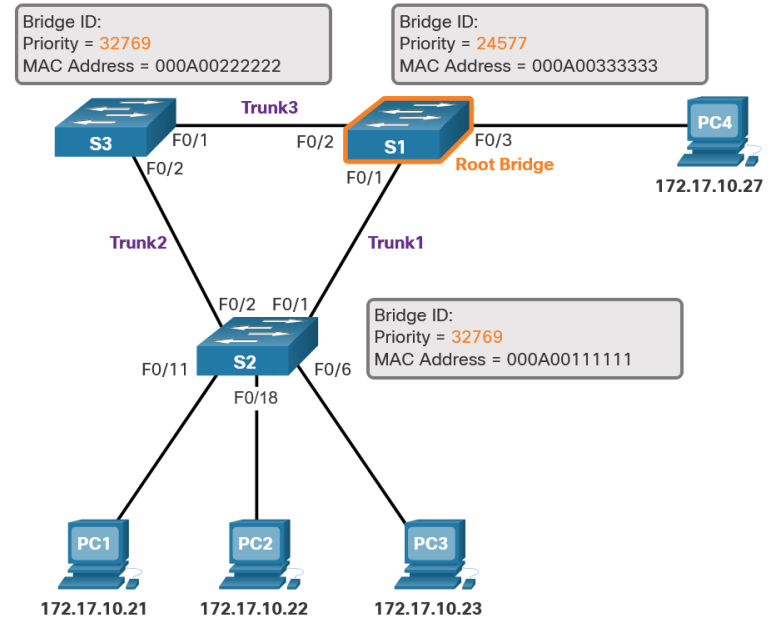
STP Root Bridge

As shown in the figure, every spanning tree instance (switched LAN or broadcast domain) has a switch designated as the root bridge.

The root bridge serves as a reference point for all spanning tree calculations to determine which redundant paths to block.

An election process determines which switch becomes the root bridge.

After a switch boots, it begins to send out BPDU frames every two seconds. These BPDU frames contain the switch BID and the root ID. Eventually, the switch with the lowest BID ends up being identified as the root bridge for the spanning tree instance.



STP Path Cost

The path information is determined by summing up the individual port costs along the path from the destination to the root bridge. Each “destination” is actually a switch port.

The default port costs are defined by the speed at which the port operates.

Link Speed and Name	Cost (Revised IEEE Specification)	Cost (Previous IEEE Specification)
10 Gb/s	2	1
1 Gb/s	4	1
100 Mb/s	19	10
10 Mb/s	100	100

To configure the port cost of an interface, enter the **spanning-tree cost *value*** command in interface configuration mode. The *value* can be between 1 and 200,000,000.

To verify the port and path cost to the root bridge, enter the **show spanning-tree** command.

Select the Root Bridge

When an administrator wants a specific switch to become a root bridge, the bridge priority value must be adjusted to ensure it is lower than the bridge priority values of all the other switches on the network.

There are two different methods to configure the bridge priority value on a Cisco Catalyst switch.

- To ensure that the switch has the lowest bridge priority value, use the **spanning-tree vlan *vlan-id* root primary** command in global configuration mode. If an alternate root bridge is desired, use the **spanning-tree vlan *vlan-id* root secondary** global configuration mode command.
- Another method for configuring the bridge priority value is using the **spanning-tree vlan *vlan-id* priority *value*** global configuration mode command. This command gives more granular control over the bridge priority value. The priority value is configured in increments of 4,096 between 0 and 61,440.

Video - Observe STP Operation

This video will demonstrate the use of Spanning Tree Protocol (STP) in a network environment.

Packet Tracer - Investigate STP Loop Prevention

In this Packet Tracer activity, you will complete the following objectives:

- Create and configure a simple three switch network with STP.
- View STP operation.
- Disable STP and view operation again.

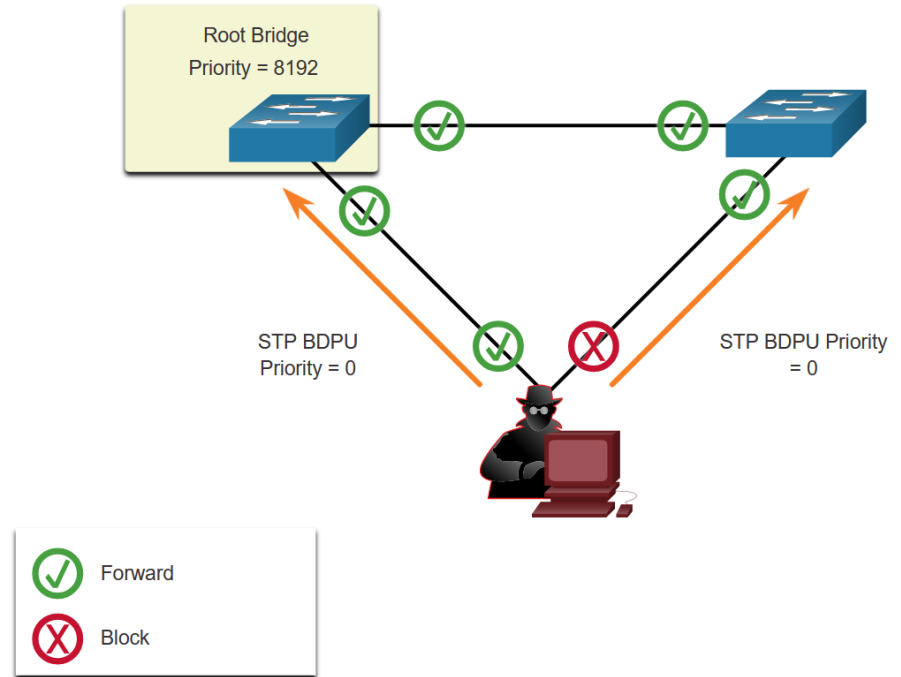
14.9 Mitigate STP Attacks

Mitigate STP Attacks

STP Attack

Threat actors can manipulate the Spanning Tree Protocol (STP) to conduct an attack by spoofing the root bridge and changing the topology of a network. Attackers can make their hosts appear as root bridges; and therefore, capture all traffic for the immediate switched domain.

To conduct an STP manipulation attack, the attacking host broadcasts STP bridge protocol data units (BPDUs) containing configuration and topology changes that will force spanning-tree recalculations, as shown in the figure. The BPDUs that are sent by the attacking host announce a lower bridge priority in an attempt to be elected as the root bridge.



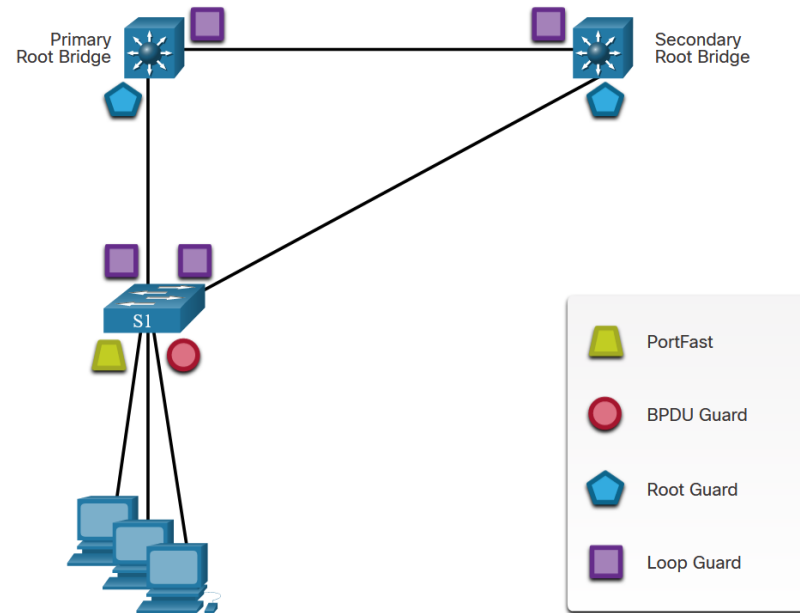
Mitigating STP Attacks

To mitigate STP manipulation attacks, use the Cisco STP stability mechanisms to enhance the overall performance of the switches and to reduce the time that is lost during topology changes.

These are the STP stability mechanisms:

- PortFast
- BPDU Guard
- Root Guard
- Loop Guard

The figure highlights the ports on which these features should be implemented.



Configure PortFast

PortFast can be enabled on an interface by using the **spanning-tree portfast** interface configuration command. Alternatively, Portfast can be configured globally on all access ports by using the **spanning-tree portfast default** global configuration command.

To verify whether PortFast is enabled globally you can use either the **show running-config | begin span** command or the **show spanning-tree summary** command.

To verify if PortFast is enabled an interface, use the **show running-config interface *type/number*** command. The **show spanning-tree interface *type/number* detail** command can also be used for verification.

Configure BPDU Guard

BPDU Guard can be enabled on a port by using the **spanning-tree bpduguard enable** interface configuration command. Alternatively, use the **spanning-tree portfast bpduguard default** global configuration command to globally enable BPDU guard on all PortFast-enabled ports.

To display information about the state of spanning tree, use the **show spanning-tree summary** command.

Always enable BPDU Guard on all PortFast-enabled ports.

Configure Root Guard

Root guard is best deployed on ports that connect to switches that should not be the root bridge. If a root-guard-enabled port receives BPDUs that are superior to those that the current root bridge is sending, that port is moved to a root-inconsistent state. This is effectively equal to an STP listening state, and no data traffic is forwarded across that port. Recovery occurs as soon as the offending device ceases to send superior BPDUs.

Use the **spanning-tree guard root** interface configuration command to configure root guard on an interface.

To view Root Guard ports that have received superior BPDUs and are in a root-inconsistent state, use the **show spanning-tree inconsistent ports** command.

Configure Loop Guard

A Layer 2 loop is usually created when an STP port in a redundant topology stops receiving BPDUs and erroneously transitions to the forwarding state.

The STP Loop Guard feature provides additional protection against Layer 2 loops. If BPDUs are not received on a non-designated Loop Guard-enabled port, the port transitions to a loop-inconsistent blocking state, instead of the listening / learning / forwarding state. Without the Loop Guard feature, the port would assume a designated port role and create a loop.

Loop Guard is enabled on all non-Root Guard ports using the **spanning-tree guard loop** interface configuration command.

Loop Guard can also be enabled globally using the **spanning-tree loopguard default** global configuration command. This enables Loop Guard on all point-to-point links.

Lab – Configure STP Security

In this lab, you will complete the following objectives:

- Part 1: Configure basic switch settings.
- Part 2: Configure secure trunks ports.
- Part 3: Protect against STP attacks.
- Part 4: Configure port security and disable unused ports.

Packet Tracer – Implement STP Security

In this Packet Tracer, you will complete the following objectives:

- Assign the Central switch as the root bridge.
- Secure spanning-tree parameters to prevent STP manipulation attacks.
- Enable port security to prevent MAC table overflow attacks

Packet Tracer - Layer 2 VLAN Security

In this Packet Tracer, you will complete the following objectives to configure security on Layer 2 switches:

- Configure basic settings.
- Configure SSH.
- Configure secure trunks and access ports by enabling features including port security, root guard, BPDU guard, loop guard and PVLAN Edge.
- Configure DHCP Snooping.

14.10 Layer 2 Security Considerations Summary

What Did I Learn in this Module?

- If Layer 2 is disrupted by a cyber attack, all layers above it will be affected.
- It is important to protect Layer 2 by always using secure variants of protocols such as SSH, SCP, and SSL.
- In addition, ACLs should be used to filter unwanted access. Port security, DHCP Snooping, DAI, and IP Source Guard are available on Cisco switches to directly mitigate Layer 2 attacks.
- One type of Layer 2 attack floods the switch with frames with random MAC source addresses.
- Threat actor tools such as macof can quickly overwhelm the MAC table of a switch causing a MAC table overflow exploit.
- A simple but effective way to prevent Layer 2 attacks is to shutdown all unused ports. Port security is a simple way to directly address MAC address overflow attacks.
- VLAN hopping and VLAN double-tagging attacks enable threat actors to access VLANs that they are not authorized to access.

What Did I Learn in this Module? (Cont.)

- In VLAN hopping attacks, a threat actor connects a host computer to a switch and then attempts to negotiate the switchport to become trunk using DTP.
- In VLAN double-tagging attacks, a threat actor adds a false VLAN tag to malicious traffic in addition to the legitimate tag.
- Private VLAN promiscuous ports can be vulnerable to PVLAN proxy attacks.
- PVLAN proxy attacks can be mitigated through the use of access control lists.
- Two types of DHCP attacks are DHCP starvation and DHCP spoofing.
- The goal of the DHCP starvation attack is DoS for connecting clients.
- A DHCP spoofing attack occurs when a rogue DHCP server is connected to the network and provides false IP configuration parameters to legitimate clients.
- Both DHCP attacks are mitigated by implementing DHCP snooping.
- Any host can claim to be the owner of any IP and MAC address.
- MAC address spoofing attacks occur when threat actors alter the MAC address of their host to match another known MAC address of a target host.

What Did I Learn in this Module? (Cont.)

- DAI, which requires DHCP snooping to be enabled, can mitigate ARP spoofing by ensuring that only valid ARP Requests and Replies are sent into the network.
- IP address spoofing is when a rogue PC hijacks a valid IP address of a neighbor, or a uses a random IP address.
- To protect against MAC and IP address spoofing, configure IPSG. IPSG operates like DAI, but it looks at every packet, not just the ARP packets.
- STP is a loop-prevention network protocol that allows for redundancy while creating a loop-free Layer 2 topology.
- Threat actors can manipulate the STP to conduct an attack by spoofing the root bridge and changing the topology of a network.
- Cisco switches have a number of STP stability mechanisms such as PortFast, BPDU Guard, Root Guard, and Loop Guard.

New Terms and Commands

- | | |
|---|--|
| <ul style="list-style-type: none">• MAC address flooding attack• macof• switchport port-security• show port-security interface• switchport port-security maximum <i>value</i>• switchport port-security mac-address <i>mac-address</i>• switchport port-security mac-address sticky• Port security aging• switchport port-security violation { protect restrict shutdown}• error-disabled• show port-security address• mac address-table notification• VLAN double-tagging attack• VLAN hopping attack | <ul style="list-style-type: none">• Dynamic Trunking Protocol (DTP)• switchport nonegotiate• switchport trunk native vlan <i>vlan_number</i>• private VLANs (PVLAN)• PVLAN edge port• switchport protected• DHCP starvation attack• DHCP spoofing attack• ip dhcp snooping• ip dhcp snooping trust• ip dhcp snooping limit rate <i>value</i>• ip dhcp snooping <i>vlan</i>• show ip dhcp snooping binding• IP-to-MAC binding• ARP spoofing |
|---|--|

New Terms and Commands (Cont.)

- | | |
|--|--|
| <ul style="list-style-type: none">• ip arp inspection validate {src-mac [dst-mac] [ip]}• ip verify source• show ip verify source• IEEE 802.1D• bridge protocol data unit (BPDU)• bridge ID (BID)• spanning-tree cost <i>value</i>• show spanning-tree• spanning-tree vlan vlan-id root primary• spanning-tree vlan vlan-id root secondary• spanning-tree vlan vlan-id priority value• PortFast• BPDU Guard• Root Guard• Loop Guard | <ul style="list-style-type: none">• spanning-tree portfast• spanning-tree portfast default• show spanning-tree summary• show spanning-tree interface <i>type/number</i> detail• spanning-tree bpduguard enable• spanning-tree portfast bpduguard default• show spanning-tree summary• spanning-tree guard root• show spanning-tree inconsistent ports• spanning-tree guard loop• spanning-tree loopguard default |
|--|--|

